

Microsoft 365

General Theory Notes

Complete theory – Architecture, Services, Identity, Security, Compliance, Device Management

1. What is Microsoft 365?
2. Microsoft 365 Architecture
3. Licensing Plans
4. Microsoft Entra ID (Azure AD)
5. Authentication and MFA
6. Conditional Access
7. Exchange Online
8. Microsoft Teams
9. SharePoint Online and OneDrive
10. Microsoft Intune
11. Microsoft Defender for M365
12. Microsoft Purview
13. PowerShell for M365
14. Admin Portals
15. Key Concepts and Definitions

Section 1 – What is Microsoft 365?

1.1 Definition and Overview

Microsoft 365 (formerly Office 365) is a cloud-based subscription service that combines productivity applications, cloud storage, identity management, device management, and security tools into one integrated platform. Instead of buying software licenses and managing servers, organisations subscribe per user per month and Microsoft manages all the underlying infrastructure.

Key characteristics of Microsoft 365:

- Cloud-based: everything runs in Microsoft datacenters, accessed via internet
- Subscription model: pay per user per month, no upfront hardware costs
- Always up to date: Microsoft pushes updates automatically, no manual patching
- Integrated platform: all services work together with single sign-on
- Scalable: add or remove users instantly, no infrastructure changes needed

1.2 Microsoft 365 vs Office 365 vs Azure

Name	What It Is	Relationship
Office 365	Original cloud productivity suite – email, Office apps, Teams	Now part of Microsoft 365
Microsoft 365	Expanded suite adding security, compliance and device management on top of Office 365	The current full product name
Azure AD (old name)	Cloud identity service managing users and authentication for M365	Renamed to Microsoft Entra ID in 2023
Microsoft Entra ID	New name for Azure AD – the identity backbone of all M365 services	Every M365 tenant gets one automatically
Microsoft Azure	Cloud platform for VMs, databases, AI, networking, storage	Separate product but shares Entra ID with M365

* Microsoft Entra ID IS Azure AD. They renamed it in 2023. The portal moved to entra.microsoft.com. In your CV and LinkedIn always use the NEW name: Microsoft Entra ID.

1.3 Key Services in Microsoft 365

Service	What It Does	On-Premises Equivalent
Exchange Online	Cloud email, calendar, contacts, shared mailboxes, room booking	Exchange Server
Microsoft Teams	Chat, video meetings, file sharing, channels, calling	Skype for Business + meeting rooms
SharePoint Online	Company intranet, document libraries, team sites, external sharing	SharePoint Server
OneDrive for Business	Personal cloud storage 1TB per user, sync to desktop	Network home drive (H: drive)
Microsoft 365 Apps	Word, Excel, PowerPoint, Outlook installable on 5 devices	Office perpetual license
Microsoft Entra ID	Cloud identity - users, groups, MFA, Conditional Access, SSO	Active Directory Domain Services
Microsoft Intune	Cloud device management - MDM and MAM for all platforms	SCCM + Group Policy
Defender for M365	Email security, endpoint protection, identity protection	Separate security products
Microsoft Purview	Compliance, data classification, retention, DLP, eDiscovery	Separate compliance tools

Section 2 - Microsoft 365 Architecture

2.1 Tenant Concept

A tenant is your organisation's isolated and dedicated instance of Microsoft 365 in the cloud. Every organisation that subscribes to Microsoft 365 gets their own tenant. Your tenant is completely separate from all other organisations - your data, users, and settings are isolated.

- Tenant domain: every tenant gets a default domain like `yourcompany.onmicrosoft.com`
- Custom domain: you can add your own domain like `yourcompany.com` and verify ownership via DNS
- Tenant ID: a unique GUID identifying your tenant in Microsoft systems
- Global Administrator: highest privilege role in the tenant, can do everything

* Your lab tenant: `praveenlab2026.onmicrosoft.com` - this is your dedicated isolated environment

2.2 Microsoft Datacenters and Regions

Microsoft stores your M365 data in datacenters in the region you select during tenant setup. For GDPR compliance, EU organisations should select European regions so their data stays within EU borders.

- EU regions: West Europe (Netherlands), North Europe (Ireland), France Central, Germany West Central
- Data residency: Microsoft guarantees your data stays in the selected region
- GDPR: storing EU personal data in EU datacenters satisfies data residency requirements
- Redundancy: Microsoft replicates data across multiple datacenters for resilience

2.3 Admin Portals - Where Everything is Managed

Portal	URL	Purpose
M365 Admin Center	admin.microsoft.com	Main portal - users, groups, licenses, billing, service health
Microsoft Entra Admin Center	entra.microsoft.com	Identity - users, Conditional Access, MFA, PIM, app registrations

Portal	URL	Purpose
Exchange Admin Center	admin.exchange.microsoft.com	Email – mailboxes, mail flow rules, spam, shared mailboxes
Teams Admin Center	admin.teams.microsoft.com	Teams – policies, meetings, calling, channels, external access
SharePoint Admin Center	[tenant]-admin.sharepoint.com	Sites, storage, sharing policies, external access settings
Microsoft Intune	intune.microsoft.com	Device enrollment, compliance, configuration profiles, app management
Microsoft Defender	security.microsoft.com	Threat protection, email security, endpoint security, incidents
Microsoft Purview	purview.microsoft.com	Compliance, DLP, retention, sensitivity labels, eDiscovery, audit

2.4 Service Health and Message Center

Two critical monitoring areas every M365 admin must check regularly:

– Service Health (admin.microsoft.com -> Health -> Service health): shows real-time status of all M365 services. Green = healthy, Orange = degraded, Red = major outage. ALWAYS check here first when users report problems – it may be a Microsoft issue not a local one.

– Message Center (admin.microsoft.com -> Health -> Message center): Microsoft posts announcements about new features, planned maintenance, and changes. Critical to check weekly in a real job so you are not surprised by changes.

! IT Support Rule: When a user reports a problem, check Service Health BEFORE troubleshooting the user's device. If Microsoft shows an incident, it is their fault – tell the user to wait.

Section 3 – Licensing Plans

3.1 Business Plans (up to 300 users)

Plan	Key Features	Monthly Cost
Microsoft 365 Business Basic	Web Office apps, Exchange Online, Teams, SharePoint, OneDrive, Entra ID (basic)	\$6/user
Microsoft 365 Business Standard	All Basic + installable Office apps (Word, Excel, PowerPoint, Outlook on PC)	\$12.50/user
Microsoft 365 Business Premium	All Standard + Intune, Defender for Business, Entra ID P1, Defender for Office 365 P1	\$22/user

3.2 Enterprise Plans (unlimited users)

Plan	Key Features	Monthly Cost
Microsoft 365 E3	Full desktop apps, Entra ID P1, basic compliance, no advanced security	\$36/user
Microsoft 365 E5	All E3 + Defender for Office 365 P2, Entra ID P2, Purview E5, Sentinel SIEM, Phone System	\$57/user
Microsoft 365 F3	Frontline workers – web/mobile only, no desktop apps, Teams Essentials	\$10/user

3.3 What Entra ID P1 vs P2 Adds

Feature	Free (included)	P1 (Business Premium/E3)	P2 (E5 only)
MFA	Security Defaults only	Conditional Access MFA	Risk-based MFA
Conditional Access	Not available	Full CA policies	All P1 + risk-based CA
Dynamic Groups	Not available	Available	Available
SSPR	Not available	Available	Available
PIM (Privileged Identity Management)	Not available	Not available	Available

Feature	Free (included)	P1 (Business Premium/E3)	P2 (E5 only)
Identity Protection	Not available	Not available	Available
Access Reviews	Not available	Not available	Available

3.4 How Licensing Works

Every user who needs access to M365 services must have a license assigned. Without a license, the user account exists in Entra ID but the user cannot access email, Teams, SharePoint, or any other service.

- Assign license: user gains access to all services included in that license
- Remove license: user immediately loses access to services (data preserved for 30 days)
- Usage location: must be set on user BEFORE assigning license (for legal compliance)
- Group-based licensing: assign license to a group, all members automatically get it

* Usage Location is mandatory in M365. Always set Country (e.g. Italy) on a user before assigning a license or the assignment will fail.

Section 4 – Microsoft Entra ID (formerly Azure AD)

4.1 What is Microsoft Entra ID?

Microsoft Entra ID (renamed from Azure Active Directory in 2023) is the cloud identity and access management service that powers all authentication and authorisation in Microsoft 365. When a user signs into Outlook, Teams, or SharePoint, Entra ID validates their identity before granting access.

On-Premises Active Directory	Microsoft Entra ID
Runs on Windows Server in your datacenter	Runs in Microsoft cloud datacenters – no servers needed
Uses Kerberos and NTLM protocols	Uses OAuth 2.0, OpenID Connect, SAML 2.0 modern protocols
Objects: Users, Groups, Computers, OUs, GPOs	Objects: Users, Groups, Devices, Applications, Service Principals
Computers join via Domain Join	Devices join via Entra Join or Hybrid Entra Join
Managed via ADUC, GPMC, DNS console	Managed via entra.microsoft.com and PowerShell (MS Graph)
Works with on-premises resources only	Works with cloud apps, SaaS, M365, Azure resources
MFA requires add-on (NPS extension)	MFA built-in with Authenticator app, FIDO2, SMS, voice

4.2 Entra ID Objects

Object	Description	Real World Example
User	A person with an account – can sign in and access resources	alice.johnson@company.com – an employee account
Guest User	External person invited to collaborate – uses their own credentials	client@partnerfirm.com invited to a Teams channel
Service Principal	The identity of an application running in your tenant	A custom app that reads your calendar via Graph API
Managed Identity	System-assigned identity for Azure resources (no password needed)	An Azure VM that reads Key Vault secrets automatically
Group	Collection of users for access control, email, or collaboration	IT-Admins-Security group with all IT staff members
Application	Registered app that can authenticate against Entra ID	Microsoft Teams app, custom web app, Salesforce SSO
Device	Registered or joined device managed by Entra ID/Intune	A company laptop enrolled in Intune

4.3 Group Types in Microsoft 365

Group Type	Has Email	Has SharePoint	Has Teams	Purpose
Microsoft 365 Group	Yes - shared mailbox	Yes - team site	Optional	Full collaboration workspace for a team or project
Security Group	No	No	No	Access control only - permissions to apps, sites, policies
Mail-enabled Security	Yes	No	No	Email distribution AND access control combined
Distribution List	Yes (one-way)	No	No	Email broadcasting only - newsletters, announcements
Dynamic Security	No	No	No	Auto-managed access control based on user attribute rules
Dynamic M365	Yes	Yes	Optional	Auto-managed collaboration group based on user attributes

* Dynamic Groups require Entra ID P1. They automatically add/remove members based on user properties like department, job title, or location. Example rule: (user.department -eq "IT") - all IT users auto-join this group.

4.4 Admin Roles in Microsoft 365

Role	What They Can Do	When to Assign
Global Administrator	Everything in the tenant - unlimited access	Maximum 4 people. Use sparingly. Always with MFA.
Global Reader	Read-only access to everything - cannot make changes	Auditors, security reviewers, compliance officers
User Administrator	Create/edit/delete users and groups, reset passwords	Helpdesk team leads, HR admins
Helpdesk Administrator	Reset passwords for non-admins, manage service requests	Tier 1 helpdesk staff
Exchange Administrator	Full Exchange Online control - mailboxes, mail flow	Email administrators
Teams Administrator	Full Teams control - policies, meetings, calling	Teams/collaboration administrators
SharePoint Administrator	Full SharePoint control - sites, storage, permissions	SharePoint/intranet administrators
Intune Administrator	Full device management - enrollment, compliance, apps	Endpoint/device management administrators
Security Administrator	Manage security policies, Defender, alerts, incidents	Security team members, SOC analysts
Compliance Administrator	Manage Purview, DLP, retention, eDiscovery	Compliance and legal team members
Billing Administrator	Manage subscriptions, licenses, payment methods	IT managers, finance team

! Principle of Least Privilege: always assign the MINIMUM role needed. Never use Global Administrator for daily tasks. Create a separate standard admin account and use role-specific permissions.

Section 5 - Authentication and MFA

5.1 How Authentication Works in M365

When a user signs into Microsoft 365, the authentication process goes through Microsoft Entra ID using modern authentication protocols. This is different from the old NTLM/Kerberos used in on-premises AD.

- Step 1 - User enters username and password in the browser or app
- Step 2 - Request goes to Entra ID (login.microsoftonline.com)
- Step 3 - Entra ID validates credentials against the directory
- Step 4 - If MFA is required, Entra ID challenges for second factor

- Step 5 - If Conditional Access policies apply, they are evaluated
- Step 6 - If all checks pass, Entra ID issues a token (JWT - JSON Web Token)
- Step 7 - The token is sent to the M365 service (Exchange, Teams etc.)
- Step 8 - The service validates the token and grants access

5.2 Multi-Factor Authentication (MFA)

MFA requires users to prove their identity using two or more factors. Microsoft data shows MFA blocks 99.9% of automated account compromise attacks. Even if a password is stolen, the attacker cannot sign in without the second factor.

MFA Method	Security Level	How It Works	Recommendation
Microsoft Authenticator - Push	Very High	Notification on phone, tap Approve. Number matching prevents fatigue attacks.	Recommended for all users
Microsoft Authenticator - TOTP	High	6-digit code changes every 30 seconds. Enter the code when prompted.	Good backup method
FIDO2 Hardware Key (YubiKey)	Highest	Physical key - tap or insert. Phishing-resistant - cannot be intercepted.	For admins and high-risk accounts
Windows Hello for Business	High	Biometric (face/fingerprint) or PIN on Windows device. Passwordless.	For Windows 11 devices
Temporary Access Pass (TAP)	One-time	Time-limited passcode generated by admin. Used when user loses MFA device.	Emergency use only
SMS Text Message	Medium	6-digit code sent to phone. Vulnerable to SIM swapping attacks.	Avoid if possible
Voice Call	Medium	Automated call, press # to confirm. Accessible for users without smartphones.	Fallback option only

5.3 Security Defaults vs Conditional Access

Feature	Security Defaults	Conditional Access
What it is	Simple on/off switch - baseline MFA for everyone	Granular if-then policies with many conditions and controls
Requires Entra P1	No - free with any M365 plan	Yes - requires Entra ID P1 or P2
Flexibility	None - same rules for all users	Full control - different rules per user, group, app, location, risk
Can coexist	Cannot run alongside Conditional Access	Cannot run alongside Security Defaults
Best for	Organisations with no P1 license	Any organisation with P1/P2 (Business Premium, E3, E5)
MFA enforcement	All users must register and use MFA	You define who, when, and under what conditions

5.4 Self-Service Password Reset (SSPR)

SSPR allows users to reset their own forgotten passwords without calling IT. This is a huge time saver - password resets account for 20-50% of all helpdesk tickets in most organisations. Requires Entra ID P1.

- Users register their verification methods (Authenticator app, phone, email)
- When they forget their password they go to aka.ms/sspr
- They verify their identity using registered methods
- They set a new password immediately - no IT involvement needed
- Admin can configure: how many methods required, which methods allowed, registration enforcement

* SSPR Business Impact: If 500 users each call IT once per year for password reset = 500 tickets x 15 minutes = 125 hours of IT time per year. SSPR eliminates almost all of these.

Section 6 – Conditional Access

6.1 What is Conditional Access?

Conditional Access is the intelligent security gatekeeper of Microsoft 365. Instead of just checking a password, it evaluates multiple signals (WHO is signing in, from WHERE, on WHAT device, to access WHAT app) before deciding whether to allow, block, or require additional verification.

The Conditional Access model is simple: IF (conditions are met) THEN (apply controls). Think of it as a series of if-then rules that run every time someone tries to sign in.

6.2 Signals (IF Conditions)

Signal	What You Can Check	Example Use
User or Group	Apply to all users, specific users, security groups, or directory roles	Only apply this policy to Finance department users
Cloud App	Apply to all apps, specific M365 services, or specific SaaS apps	Only require MFA for Exchange Online access
Location (IP)	User's IP address – named locations, trusted IPs, countries	Block access from outside Italy
Device Platform	Windows, iOS, Android, macOS, Linux	Apply stricter rules for iOS and Android devices
Device State	Is device enrolled in Intune? Is it compliant with policies?	Only allow compliant managed devices to access email
Sign-in Risk (P2)	Entra ID detects risky sign-in behaviour (leaked credentials, unusual location)	Require MFA if sign-in risk is Medium or High
User Risk (P2)	Account shows signs of compromise in Microsoft threat intelligence	Block access if user risk is High, force password reset

6.3 Grant Controls (THEN Actions)

Control	What Happens
Block access	Sign-in completely denied. User sees error message explaining why.
Grant – Require MFA	User must complete multi-factor authentication to proceed
Grant – Require compliant device	Device must be Intune-enrolled and meet compliance policy requirements
Grant – Require Entra hybrid join	Device must be AD domain-joined AND registered in Entra ID
Grant – Require approved app	Must use Microsoft-approved apps (e.g. Outlook app, not generic IMAP client)
Grant – Require app protection policy	Intune MAM policy must be applied to the app on the device

6.4 Common Conditional Access Policies

- CA001 – Require MFA for all users: most important baseline policy. Exclude emergency admin.
- CA002 – Block access from outside your country: geo-restriction using Named Locations
- CA003 – Require MFA for admin roles: extra protection for privileged accounts
- CA004 – Block legacy authentication: block IMAP, POP3, SMTP Auth which cannot support MFA
- CA005 – Require compliant device for email: only Intune-managed devices can access Exchange
- CA006 – Risk-based policy (P2): block sign-ins with high risk score automatically

! CRITICAL: Always create an Emergency Admin account and EXCLUDE it from all Conditional Access policies. If you lock all users including admins, you can be permanently locked out of your tenant with no recovery option.

6.5 Named Locations

Named Locations let you define specific IP ranges or countries to use in Conditional Access conditions. You can then include or exclude these locations from policies.

- IP range locations: define office network IP addresses as trusted locations
- Country locations: define countries (e.g. Italy) as allowed regions
- Trusted locations: IP-based locations marked as trusted can bypass MFA
- Use case: Require MFA from ANY location EXCEPT the office network (trusted IP range)

Section 7 – Exchange Online

7.1 What is Exchange Online?

Exchange Online is the cloud-based email and calendaring service in Microsoft 365. It replaces on-premises Exchange Server. Every licensed user gets a mailbox (50GB standard, 100GB on E3/E5, unlimited archive available).

7.2 Mailbox Types

Mailbox Type	Purpose	License Required	Notes
User Mailbox	Personal email and calendar for one user	Yes – Exchange license auto-creates it	Primary mailbox for every licensed user
Shared Mailbox	Multiple people access one inbox – no separate login	No (up to 50GB)	info@, support@, reception@ addresses
Room Mailbox	Represents a meeting room for calendar booking	No	Auto-accepts/declines meeting invitations
Equipment Mailbox	Represents bookable equipment	No	Projector, company car, camera booking
Archive Mailbox	Extended storage for older email from primary mailbox	Included in E3/E5	Auto-expanding unlimited archive available

7.3 Mail Flow Rules (Transport Rules)

Mail flow rules process ALL email passing through Exchange Online based on conditions you define. They run server-side before email reaches the user's mailbox.

- Legal disclaimer: automatically append company legal text to all outbound email
- Encryption: encrypt emails containing sensitive keywords or going to specific domains
- Block attachments: block emails with attachments over a certain size
- Routing: redirect emails to specific mailboxes based on content or sender
- Data protection: block emails containing credit card numbers leaving the organisation

* Mail flow rules are server-side – they affect ALL email regardless of what client the user uses. Unlike Outlook rules which only run when Outlook is open.

7.4 Exchange Admin Tasks

- Shared mailbox delegation: Full Access (open and read), Send As (reply as the shared mailbox), Send on Behalf (reply showing "X on behalf of Y")
- Email forwarding: forward user email to another address (common for leavers – forward to manager)
- Auto-reply/Out of Office: configure automatic replies for away periods
- Mailbox size quotas: set warning, prohibit send, and prohibit send/receive limits
- Email aliases: add alternative email addresses to a mailbox without creating new accounts

– Room mailbox booking: configure auto-accept, booking window, maximum duration, recurring meetings

7.5 Anti-Spam and Email Security

Layer	What It Does	Included In
Exchange Online Protection (EOP)	Basic anti-spam and anti-malware. Scans all inbound and outbound email automatically.	All M365 plans
Defender for Office 365 P1	Safe Attachments (sandbox analysis), Safe Links (URL rewrite and real-time check), Enhanced anti-phishing	Business Premium, E3+Defender addon, E5
Defender for Office 365 P2	All P1 + Threat Explorer, Attack Simulator, Automated Investigation and Response (AIR)	E5, standalone addon

Section 8 – Microsoft Teams

8.1 Teams Architecture

Every Microsoft Team is backed by a Microsoft 365 Group. When you create a Team, Microsoft automatically creates: a Microsoft 365 Group (membership), a SharePoint site (file storage), a shared Exchange mailbox (group email and calendar), a OneNote notebook, and a Planner board.

Component	What It Is	Notes
Team	Top-level workspace for a group or project	Can be Public (anyone joins) or Private (invite only)
Standard Channel	Topic section visible to all team members	General channel always exists, cannot be deleted
Private Channel	Visible only to specific members within the team	Has own SharePoint sub-site for files
Shared Channel	Can include people from outside the team or organisation	Requires External Identities configuration
Tab	Pinned app or content within a channel	Files, Planner, Power BI, websites, custom apps
Meeting	Video/audio session – scheduled or instant (Meet Now)	Recordings stored in OneDrive or SharePoint
Chat	Direct messages outside of teams/channels	Separate from channel posts, persistent history

8.2 Teams Policies

Teams admin policies control what features users can access. You create custom policies and assign them to specific users or groups, overriding the global (org-wide default) policy.

Policy Type	What It Controls
Meeting policy	Recording, screen sharing, lobby settings, who can present, whiteboard, reactions, meeting chat
Messaging policy	Edit/delete messages, read receipts, gifs, memes, stickers, priority notifications, voice messages
App permission policy	Which apps (first and third party) users can install and use in Teams
App setup policy	Which apps are pre-installed and pinned to the Teams navigation bar by default for users
Calling policy	PSTN calling, voicemail, call forwarding, busy-on-busy, call park settings
Live events policy	Who can create and attend live events, recording settings

8.3 External and Guest Access

Type	What It Is	Configuration
External Access (Federation)	Your users can find and communicate with Teams users from other Microsoft 365 organisations via federation	Teams Admin Center -> Org-wide settings -> External access. Can allow all orgs or specific domains only.

Type	What It Is	Configuration
Guest Access	External people invited to join specific Teams as guest members. They use their own credentials.	Teams Admin Center -> Guest access. Also requires Entra ID External Identities settings.

Section 9 – SharePoint Online and OneDrive

9.1 SharePoint vs OneDrive

Aspect	SharePoint Online	OneDrive for Business
Ownership	Organisation owns it – exists independently of any user	Individual user owns it – deleted when user leaves (after 30 days)
Default audience	Team members, department, or whole organisation	Private to the individual user only
Created by	Admin manually, or auto-created with M365 Group/Team	Auto-created for every licensed user automatically
Best for	Company files, department libraries, intranet pages, team projects	Personal work files, drafts, work in progress
Storage	1TB per site, pooled across tenant	1TB per licensed user (unlimited on E5)
Access control	Site owners manage permissions (Owner/Member/Visitor)	User controls sharing of their own files

9.2 SharePoint Site Types

- Team site: connected to a Microsoft 365 Group. Has members and owners. Best for team collaboration.
- Communication site: for broadcasting content to a large audience. Like a company intranet home page. No M365 Group attached.
- Hub site: connects multiple sites together for unified navigation and search across related sites.

9.3 SharePoint Permission Levels

Permission Level	What They Can Do
Owner (Full Control)	Manage the entire site, change permissions, add/remove members, delete the site
Member (Edit)	Add, edit, and delete content in document libraries and lists. Cannot manage site settings.
Visitor (Read)	View and download content only. Cannot add, edit, or delete anything.
Custom	Create custom permission levels with specific granular permissions for special requirements

9.4 External Sharing Settings

SharePoint has four levels of external sharing from most to least permissive:

- Anyone: users can share with anyone using anonymous links – no sign-in required
 - New and existing guests: share with external people who must sign in with Microsoft account
 - Existing guests only: can only share with guests already in your Entra ID directory
 - Only people in your organisation: no external sharing at all – most restrictive
- * In regulated industries (finance, healthcare, legal) external sharing is often set to "Only people in your organisation" to prevent accidental data leakage.

Section 10 – Microsoft Intune

10.1 MDM vs MAM

Feature	MDM (Mobile Device Management)	MAM (Mobile Application Management)
What is managed	The ENTIRE device	Only specific APPS on the device

Feature	MDM (Mobile Device Management)	MAM (Mobile Application Management)
Device enrollment	Required – device must register in Intune	Not required – works on unmanaged devices
Best for	Company-owned devices (laptops, phones)	Personal devices (BYOD – Bring Your Own Device)
Remote wipe	Can wipe entire device	Can wipe only company app data, not personal data
Controls	Encryption, PIN, firewall, updates, certificates	App PIN, copy-paste restrictions, block screenshots
Example scenario	Company issues laptop -> enrolled in Intune -> full management	Employee uses personal iPhone for work email -> Outlook app managed, personal photos untouched

10.2 Compliance Policies

Compliance policies define minimum security requirements that devices must meet. Devices that do not comply are marked Non-compliant and can be blocked from accessing M365 resources via Conditional Access.

- BitLocker encryption required: disk must be encrypted
- Minimum OS version: device must run at least Windows 10 20H1 / iOS 15 / Android 10
- PIN or password required: device must have a screen lock
- Antivirus required: Windows Defender or compatible antivirus must be active
- Firewall required: Windows Firewall must be enabled
- Secure boot required: UEFI secure boot must be enabled

* Compliance policy + Conditional Access = Zero Trust device access. Only devices that PROVE they meet security requirements can access company data. This is how modern enterprise IT security works.

10.3 Configuration Profiles

Configuration profiles push settings to devices automatically. Users cannot change these settings – they are enforced by Intune. This replaces Group Policy for cloud-managed devices.

- Windows Update settings: configure update rings, maintenance windows, automatic installation
- Wi-Fi profiles: push corporate Wi-Fi credentials to devices without user needing to know the password
- VPN profiles: automatically configure VPN connection on devices
- Email profiles: configure Outlook email account settings automatically
- Certificate profiles: deploy certificates for Wi-Fi, VPN, and email authentication
- Defender Antivirus: configure scan schedules, cloud protection, real-time monitoring

10.4 Windows Autopilot

Autopilot allows new Windows 11 PCs to be shipped directly from the manufacturer to an employee's home. The employee powers it on, signs in with their work account, and Autopilot automatically sets up everything.

- Device registers its hardware hash with Autopilot profile before shipping
- Employee unboxes and powers on – sees customised company setup screen
- Employee signs in with their M365 account
- Device automatically joins Entra ID and enrolls in Intune
- Compliance policy applied and checked
- Configuration profiles pushed automatically (Wi-Fi, VPN, certificates)
- Required apps installed silently in background
- Employee is productive within 1 hour – Zero IT Touch deployment

10.5 App Protection Policies (MAM)

App protection policies control how company data is used within specific apps on personal devices without requiring full device enrollment. Very important for BYOD scenarios.

- Require app PIN: user must enter a PIN to open the Outlook app
- Block copy-paste: cannot copy from Outlook and paste into WhatsApp or personal apps

- Block screenshots: prevents screen capture within managed apps
- Block save to personal storage: cannot save attachments to iCloud, Google Drive, USB
- Minimum app version: block old vulnerable versions of the app
- Selective wipe: admin can wipe ONLY company data from the app, not the whole device

Section 11 – Microsoft Defender for M365

11.1 Defender Products Overview

Product	What It Protects	Key Features
Exchange Online Protection (EOP)	Email – inbound and outbound	Anti-spam, anti-malware. Included in ALL M365 plans.
Defender for Office 365 P1	Email and collaboration (Teams, SharePoint)	Safe Attachments, Safe Links, enhanced anti-phishing
Defender for Office 365 P2	All P1 + advanced analysis	Threat Explorer, Attack Simulator, AIR (Automated Investigation and Response)
Defender for Business	Endpoints (Windows, Mac, iOS, Android)	Antivirus, EDR, vulnerability management. Included in Business Premium.
Defender for Endpoint P1	Endpoints (enterprise)	Antivirus, attack surface reduction, basic EDR
Defender for Endpoint P2	Endpoints (enterprise advanced)	All P1 + full EDR, threat hunting, automated investigation
Defender for Identity	On-premises AD and Entra ID	Detects lateral movement, pass-the-hash, DCSync, golden ticket attacks
Defender for Cloud Apps	SaaS applications	Shadow IT discovery, DLP for SaaS apps, CASB functionality

11.2 Safe Attachments

Safe Attachments opens ALL email attachments in Microsoft's isolated virtual sandbox BEFORE delivering them to the user. If the attachment is malicious, it is blocked. This catches zero-day malware that signature-based antivirus misses.

- How it works: attachment is detonated in a sandboxed VM
- The VM observes all behaviour: file system changes, network connections, registry modifications
- If any malicious behaviour is detected: attachment is blocked, email is quarantined
- Safe message: attachment is cleaned and delivered with a delay of 1-5 minutes
- Actions: Monitor (allow but log), Block, Replace (remove attachment and deliver email), Dynamic Delivery (deliver email immediately, attachment added later after scanning)

! Without Safe Attachments: malicious Word document arrives, user opens it, macro runs, ransomware installs. With Safe Attachments: the document is detonated in sandbox first, ransomware behaviour is detected, email is blocked before user sees it.

11.3 Safe Links

Safe Links rewrites all URLs in emails and Office documents with Microsoft proxy URLs. When a user clicks a link, Microsoft checks it against threat intelligence in real-time. If the URL became malicious AFTER delivery (time-of-click protection), the user is blocked even if they click hours later.

- URL rewriting: original URL replaced with <https://safelinks.protection.outlook.com/?url=...>
- Real-time check: when user clicks, Microsoft checks the destination URL at that exact moment
- Time-of-click protection: catches URLs that become malicious after email delivery
- "Do not let users click through": prevents users from bypassing the Safe Links warning
- Covers: emails, Teams messages, Office documents (Word, Excel, PowerPoint)

11.4 Anti-Phishing Policy

- Impersonation protection: detects emails pretending to be from specific protected users or domains

- Mailbox intelligence: uses communication patterns to identify unusual senders
- Phishing threshold: set from 1 (standard) to 4 (most aggressive) - higher = more emails caught but more false positives
- Actions: Move to Junk, Quarantine, Delete, Redirect to another mailbox
- Spoof intelligence: detects when senders are spoofing your own domain

Section 12 – Microsoft Purview

12.1 What is Microsoft Purview?

Microsoft Purview is the compliance and data governance platform in Microsoft 365. It helps organisations meet regulatory requirements (GDPR, ISO 27001, SOC 2, HIPAA) by controlling what data exists, where it lives, who can access it, and how long it is retained.

12.2 Retention Policies

Retention policies ensure data is kept for the minimum required time (legal requirement) or deleted after the maximum allowed time (GDPR data minimisation). They work silently in the background without affecting users.

- Retain: keep data for a specific period regardless of whether users delete it
- Delete: automatically delete data after a defined period
- Retain then delete: keep for X years then automatically delete
- Locations: Exchange mailboxes, Teams chats, Teams channels, SharePoint sites, OneDrive

* Italian law (DPR 633/1972) requires fiscal documents including business-related emails to be retained for 10 years. VAT records: 5 years.
Employment records: varies by type. Retention policies enforce this automatically.

12.3 Data Loss Prevention (DLP)

DLP policies detect and prevent sensitive information from being shared inappropriately. They scan content in real-time and can block, warn, or notify when sensitive data is detected.

- Sensitive information types: credit card numbers, tax IDs, passport numbers, IBAN, medical records
- Policy tips: show users a warning in Outlook before they send sensitive data externally
- Block: prevent email with credit card numbers from being sent outside the organisation
- Audit: log when sensitive data is shared without blocking (monitoring mode)
- Locations: Exchange, SharePoint, OneDrive, Teams, Endpoint devices

! GDPR relevance: DLP directly supports GDPR Article 32 (security of processing). Blocking unencrypted personal data from leaving the organisation demonstrates appropriate technical measures.

12.4 Sensitivity Labels

Sensitivity labels let users classify documents and emails with a label like Public, Internal, Confidential, or Highly Confidential. The label can enforce encryption, add watermarks, and restrict access.

- Manual labelling: user selects the appropriate label when creating a document
- Auto-labelling: system automatically applies a label when sensitive content is detected
- Encryption: Confidential label can encrypt the document so only specific people can open it
- Watermark: automatically add "CONFIDENTIAL" watermark to all pages
- Header/footer: add classification banner to top or bottom of documents
- Access control: set expiry dates, restrict printing, prevent forwarding

12.5 Audit Logs

Audit logs record every admin and user action in Microsoft 365. They are critical for security investigations, compliance evidence, and regulatory audits. Available in Microsoft Purview -> Audit.

- User activities: file access, deletion, sharing, login events
- Admin activities: mailbox changes, policy changes, role assignments, user creation/deletion

- Exchange activities: email send, receive, delete, forwarding rule changes
- SharePoint activities: file upload, download, share, permission changes
- Retention: 90 days for E3, 1 year for E5 (can extend to 10 years with add-on)
- * Common audit investigation scenarios: Who deleted these files? (FileDeleted), Who gave this user admin rights? (Add member to role), Did this employee download everything before leaving? (FileDownloaded)

Section 13 – PowerShell for M365

13.1 PowerShell Modules for M365

Module	What It Manages	Install Command
Microsoft.Graph	Users, groups, licenses, Entra ID (modern - replaces MSOnline and AzureAD modules)	Install-Module Microsoft.Graph
ExchangeOnlineManagement	Exchange Online mailboxes, mail flow, permissions	Install-Module ExchangeOnlineManagement
MicrosoftTeams	Teams policies, channels, meetings, calling	Install-Module MicrosoftTeams
Microsoft.Online.SharePoint.PowerShell	SharePoint sites, storage, sharing	Install-Module Microsoft.Online.SharePoint.PowerShell

13.2 Connecting to Services

- Microsoft Graph: Connect-MgGraph -Scopes "User.ReadWrite.All","Group.ReadWrite.All"
- Exchange Online: Connect-ExchangeOnline -UserPrincipalName admin@tenant.onmicrosoft.com
- Microsoft Teams: Connect-MicrosoftTeams
- SharePoint Online: Connect-SPOService -Url https://tenant-admin.sharepoint.com
- Always disconnect when done: Disconnect-MgGraph, Disconnect-ExchangeOnline -Confirm:\$false

13.3 Essential Microsoft Graph Commands

- Get-MgUser -All | Select DisplayName, UserPrincipalName, AccountEnabled
- New-MgUser -DisplayName "Name" -UserPrincipalName "upn" -AccountEnabled -PasswordProfile \$pp
- Update-MgUser -UserId "upn" -Department "IT" -JobTitle "Engineer"
- Update-MgUser -UserId "upn" -AccountEnabled:\$false # disable/block user
- Remove-MgUser -UserId "upn" # delete user (goes to deleted users for 30 days)
- Get-MgSubscribedSku | Select SkuPartNumber, ConsumedUnits # view licenses
- Set-MgUserLicense -UserId "upn" -AddLicenses @(\$LicObj) -RemoveLicenses @() # assign license

13.4 Essential Exchange Online Commands

- Get-EXOMailbox -ResultSize Unlimited | Select DisplayName, PrimarySmtpAddress
- Get-EXOMailboxStatistics -Identity "upn" | Select TotalItemSize, ItemCount
- New-Mailbox -Shared -Name "IT Support" -PrimarySmtpAddress "support@tenant.com"
- Add-MailboxPermission -Identity "shared@" -User "user@" -AccessRights FullAccess
- Add-RecipientPermission "shared@" -AccessRights SendAs -Trustee "user@"
- Set-MailboxAutoReplyConfiguration -Identity "upn" -AutoReplyState Enabled -InternalMessage "On leave"
- Set-Mailbox -Identity "upn" -ForwardingSmtpAddress "manager@" -DeliverToMailboxAndForward \$true
- Get-TransportRule | Select Name, Priority, State # list mail flow rules

Section 14 – Admin Portals Quick Reference

14.1 M365 Admin Center (admin.microsoft.com)

- Home: dashboard with service health, message center, quick actions
- Users -> Active users: create, edit, delete, block, reset password, assign licenses
- Users -> Deleted users: restore deleted users within 30 days
- Users -> Guest users: invite and manage external collaborators
- Groups -> Active groups: create and manage M365 Groups, Security Groups, Distribution Lists
- Roles -> Role assignments: assign admin roles to users
- Billing -> Your products: view subscriptions and trial status
- Billing -> Licenses: see license usage and assignment
- Health -> Service health: real-time status of all M365 services
- Health -> Message center: Microsoft announcements and planned changes
- Reports -> Usage: adoption reports for all M365 services

14.2 Microsoft Entra Admin Center (entra.microsoft.com)

- Identity -> Users -> All users: detailed user management and Entra ID properties
- Identity -> Groups -> All groups: all group types including dynamic groups
- Identity -> Devices: registered and Entra-joined devices
- Protection -> Conditional Access -> Policies: create and manage CA policies
- Protection -> Authentication methods -> Policies: enable/disable MFA methods
- Protection -> Password reset: configure SSPR
- Monitoring and health -> Sign-in logs: all sign-in attempts with location and device details
- Monitoring and health -> Audit logs: all admin and user actions in Entra ID

14.3 Security Portal (security.microsoft.com)

- Incidents and alerts: security incidents grouped from all Defender products
- Email and collaboration -> Threat policies: Safe Attachments, Safe Links, Anti-phishing, Anti-spam
- Email and collaboration -> Explorer: real-time view of all email threats
- Email and collaboration -> Attack simulation: run simulated phishing campaigns
- Assets -> Devices: all devices onboarded to Defender for Business/Endpoint
- Exposure management -> Secure score: your security posture score and improvement recommendations

14.4 Microsoft Purview (purview.microsoft.com)

- Information protection -> Labels: create and manage sensitivity labels
- Information protection -> Label policies: publish labels to users
- Data lifecycle management -> Retention policies: configure data retention rules
- Data loss prevention -> Policies: create DLP policies to protect sensitive data
- Audit: search all user and admin activity logs
- eDiscovery: create legal holds and search for content for legal cases

Section 15 – Key Concepts and Definitions

15.1 Identity Concepts

- Single Sign-On (SSO): sign in once to Entra ID and access all connected apps without re-entering credentials
- OAuth 2.0: modern authorisation protocol. M365 uses it to grant apps access to resources on behalf of users
- OpenID Connect (OIDC): authentication layer on top of OAuth 2.0. Used for user identity verification
- SAML 2.0: older federation protocol used for SSO with enterprise apps that do not support OIDC
- JWT (JSON Web Token): the token issued by Entra ID after successful authentication. Contains claims about the user.
- Claim: a piece of information about the user inside the JWT – e.g. display name, email, group memberships, roles

- Tenant ID: unique GUID identifying your M365 tenant in Microsoft systems
- Object ID: unique GUID identifying a specific user, group, or app within your tenant
- UPN (User Principal Name): a user's login identifier - always in email format (user@domain.com)

15.2 Security Concepts

- Zero Trust: security model that assumes no user or device is trusted by default. Always verify, never trust. Verify explicitly, use least privilege, assume breach.
- Least Privilege: assign only the minimum permissions needed to do the job. Do not give Global Admin when User Admin is enough.
- JML (Joiner Mover Leaver): the user lifecycle process. Joiner = new hire setup. Mover = transfer between departments. Leaver = account closure process.
- MFA Fatigue Attack: attacker floods user with MFA push notifications hoping they approve one. Microsoft Authenticator number matching defends against this.
- SIM Swapping: attacker convinces mobile carrier to transfer victim's phone number to attacker's SIM. Bypasses SMS MFA. Reason to avoid SMS as MFA method.
- Legacy Authentication: old email protocols (IMAP, POP3, SMTP Auth, Basic Auth) that cannot support MFA. Must be blocked via Conditional Access.
- Phishing-Resistant MFA: FIDO2 hardware keys and Windows Hello are phishing-resistant because they use cryptographic keys tied to the specific website - they cannot be intercepted and replayed on a fake site.

15.3 Licensing Abbreviations

- SKU (Stock Keeping Unit): Microsoft's internal name for a license. Business Premium SKU = SPB
- MAU (Monthly Active User): a user who actively uses a service at least once per month
- CAL (Client Access License): old on-premises licensing model. Cloud M365 does not use CALs.
- E1/E3/E5: Enterprise license tiers. E5 is highest with all security and compliance features.
- F1/F3: Frontline worker licenses for shift workers - web and mobile only, no desktop apps

15.4 Common Acronyms

Acronym	Full Name	Context
AAD / Entra ID	Azure Active Directory / Microsoft Entra ID	Cloud identity service
AD DS	Active Directory Domain Services	On-premises directory
CA	Conditional Access	Identity security policy
DLP	Data Loss Prevention	Compliance - protect sensitive data
EDR	Endpoint Detection and Response	Advanced endpoint security
EOP	Exchange Online Protection	Basic email security
FIDO2	Fast Identity Online 2	Hardware MFA standard
GDPR	General Data Protection Regulation	EU privacy law
IAM	Identity and Access Management	Managing who has access to what
JML	Joiner Mover Leaver	User lifecycle process
MAM	Mobile Application Management	Manage apps on personal devices
MDM	Mobile Device Management	Manage entire devices
MFA	Multi-Factor Authentication	Two or more identity factors
MSSP	Managed Security Service Provider	Third party security monitoring
OIDC	OpenID Connect	Modern authentication protocol

Acronym	Full Name	Context
PIM	Privileged Identity Management	Just-in-time admin access (P2)
RBAC	Role-Based Access Control	Permissions based on role not individual
SKU	Stock Keeping Unit	Microsoft license product code
SSO	Single Sign-On	One login for many applications
SSPR	Self-Service Password Reset	Users reset own passwords
TAP	Temporary Access Pass	Emergency one-time MFA passcode
UPN	User Principal Name	User login email address

15.5 Microsoft Secure Score

Microsoft Secure Score is a measurement of your organisation's security posture. It scores you out of a maximum possible number of points based on which security controls you have implemented. The higher the score, the better your security.

- Found at: security.microsoft.com -> Exposure management -> Secure score
- Recommended actions: specific steps to improve your score with implementation guides
- History: track your score improvement over time
- Common high-value improvements: enable MFA, enable audit logging, enable SSPR, block legacy auth, enable Safe Attachments and Safe Links

* In interviews: "I improved our Secure Score from 35% to 72% by implementing MFA for all users, blocking legacy authentication, enabling Safe Attachments and Safe Links, and configuring SSPR" is a very strong answer that shows real security initiative.

End of Notes - Microsoft 365 General Theory

15 Sections - Architecture, Identity, Security, Compliance, Device Management, PowerShell